

Безопасность и КИИ ЦП РСФСР

Документ описывает модель угроз, систему защиты информации, режим эксплуатации платформы как объекта критической информационной инфраструктуры (ФЗ-187).

1. Категоризация ИС

Параметр	Значение
Категория объекта КИИ (ФЗ-187)	1 (наивысшая значимость)
Уровень защищённости ПДн (ПП РФ №1119)	УЗ-1
Уровень защиты по ГОСТ Р 57580.1	4 (максимальный)
Класс ГИС (Приказ ФСТЭК №17)	К1
Тип СЗИ	Сертифицированные ФСТЭК / ФСБ

2. Модель угроз

Модель угроз построена в соответствии с банком данных угроз ФСТЭК России (БДУ ФСТЭК) и Методическим документом ФСТЭК «Методика оценки угроз безопасности информации» (2021 г.).

Ключевые группы угроз

- Внешние нарушители (high motivation):** АРТ-группы, нацеленные на финансовую и государственную инфраструктуру РФ. Цели: похищение средств, нарушение работы платформы, компрометация эмиссионного контура.
- Внутренние нарушители:** недобросовестные сотрудники оператора, подрядчиков, партнёров.
- Социальная инженерия:** фишинг сотрудников оператора и пользователей платформы.
- Атаки на цепочку поставок (supply chain):** компрометация СЗИ, библиотек, обновлений.
- DDoS-атаки:** на публичные интерфейсы и API.
- Атаки на криптографию:** попытки компрометации ключей, перехвата сессий.
- Физические угрозы:** проникновение в ЦОД, кража носителей.
- Угрозы доступности:** отказы железа, ошибки эксплуатации.
- Угрозы целостности данных:** модификация записей в БД и реестрах.
- Угрозы конфиденциальности:** утечки ПДн и финансовых сведений.

Уровни ущерба

- Уровень I (катастрофический): компрометация эмиссионного контура; недопустим, требует максимальной защиты.
- Уровень II (тяжёлый): массовая утечка ПДн; недопустим.

- Уровень III (умеренный): отказ единичного компонента; восстанавливается в RTO.

3. Система защиты информации (СЗИ)

3.1. Защита периметра

- NGFW отечественной разработки (UserGate / SolarSpace).
- WAF (PT Application Firewall).
- Anti-DDoS (Qrator Labs Russia / Stormwall).
- Anti-bot защита.
- Сегментация сети по zero-trust принципам.

3.2. Защита рабочих станций администраторов

- EDR (Kaspersky EDR Expert / R-Vision EDR).
- DLP (Solar Dozor / InfoWatch).
- Контроль съёмных носителей (с запретом по умолчанию).
- Двухфакторная аутентификация для всех админ-доступов.

3.3. Защита данных

- Шифрование данных at rest (КриптоПро Disk).
- Шифрование данных in transit (ГОСТ TLS, ВипНет).
- Маскирование ПДн в нерабочих средах.
- Tokenization чувствительных полей (БД).
- Backup на зашифрованных носителях.

3.4. Защита приложений

- Безопасная разработка (Secure SDLC):
 - SAST на каждом коммите;
 - DAST еженедельно;
 - SCA (software composition analysis);
 - Пентест по релизам.
- Подпись релизов УКЭП.
- Изолированные runtime-среды (gVisor / Kata Containers).

3.5. Управление доступом

- Принцип минимальных привилегий.
- RBAC + ABAC на уровне сервисов.
- Двухфакторная аутентификация для всех сотрудников.
- Privileged Access Management (PAM) для администраторов.
- Журналирование всех привилегированных операций.

3.6. Криптографические компоненты

- HSM КриптоПро / ВипНет — для хранения корневых ключей.

- Регулярная ротация ключей (минимум раз в 12 месяцев для рабочих, каждые 5 лет для корневых).
- Аппаратные токены УКЭП для сотрудников.

4. Соответствие нормативным требованиям

4.1. ФЗ-187 «О безопасности КИИ»

- Категорирование объекта КИИ проведено в установленном порядке.
- Уведомление направлено в ФСТЭК.
- Подключение к ГосСОПКА — через защищённый канал.
- Назначен ответственный за обеспечение безопасности значимых объектов КИИ.
- Регулярное взаимодействие с НКЦКИ.

4.2. Указание Банка России №6635-У

- Регламент обработки инцидентов ИБ.
- Уведомление Банка России в установленные сроки (24 ч / 72 ч / 30 дней в зависимости от категории).
- Журнал инцидентов с хранением не менее 5 лет.

4.3. Приказ ФСТЭК №239

- Применение СЗИ для значимых объектов КИИ 1 категории.
- Регулярные проверки соответствия.

4.4. Приказ ФСТЭК №17 (К1 — государственная ИС)

- Применение СЗИ от НСД, контроль действий администраторов.
- Регулярная аттестация ИС.

4.5. Приказ ФСТЭК №21 (УЗ-1 ИСПДн)

- Соответствие требованиям к защите ПДн.

4.6. ГОСТ Р 57580.1 (уровень 4)

- Реализация всех 8 направлений защиты.
- Регулярная оценка соответствия по ГОСТ Р 57580.2 внешним аудитором.

5. Операционная модель ИБ

5.1. SOC 24×7

- L1 — мониторинг и первичная классификация.
- L2 — реагирование на инциденты, контейнмент.
- L3 — расследование, root-cause analysis, остановка атаки.
- Threat hunting — проактивный поиск угроз.

5.2. Threat Intelligence

- Подключение к BDU ФСТЭК.
- Подписка на отчёты НКЦКИ и Банка России.
- Внутренний TI-сервис (R-Vision TIP / отечественный аналог).

5.3. Управление уязвимостями

- Сканирование инфраструктуры — еженедельно.
- Сканирование приложений (DAST) — еженедельно.
- Пентест внешний — ежегодно аккредитованной лабораторией.
- Пентест внутренний — раз в полугодие силами Red Team.

5.4. Аудит и compliance

- Ежегодный внутренний аудит ИБ.
- Ежегодный внешний аудит соответствия ГОСТ Р 57580.1.
- Регулярные проверки регуляторов (ЦБ, ФСТЭК, ФСБ, Роскомнадзор).

6. План реагирования на инциденты

6.1. Категории инцидентов

- **Категория А (критический):** компрометация эмиссионного контура, ключей УКЭП, массовая утечка ПДн.
- **Категория В (высокий):** компрометация отдельного сервиса, попытка несанкционированного выпуска ЦФА.
- **Категория С (средний):** подозрительная активность, единичные инциденты.
- **Категория D (низкий):** фоновые события.

6.2. Регламент реагирования

1. Обнаружение → классификация (5 мин).
2. Уведомление руководства SOC (10 мин).
3. Контейнмент (15 мин для критичных).
4. Уведомление Банка России и ГосСОПКА (1 ч для критичных).
5. Расследование и устранение.
6. Post-mortem и lessons learned.

7. Защита персональных данных

7.1. Принципы

- Privacy by Design.
- Минимизация сбора данных.
- Согласия пользователей оформляются в ЕСИА с возможностью отзыва.
- Право на доступ, исправление, удаление (152-ФЗ).
- Передача только в уполномоченные органы.

7.2. Локализация

- Все ПДн хранятся и обрабатываются исключительно на территории Российской Федерации (152-ФЗ ст. 18).

8. Регулярные практики

Практика	Периодичность
Внешний пентест	ежегодно
Внутренний пентест (Red Team)	раз в 6 месяцев
DR-учения	ежеквартально
Tabletop exercises	раз в 6 месяцев
Аудит соответствия ГОСТ Р 57580.2	ежегодно
Обновление модели угроз	раз в полугодие
Обновление политик ИБ	ежегодно
Обучение персонала ИБ-грамотности	ежеквартально
Phishing simulation	ежемесячно